

Chapitre 4

L'atténuation des risques — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — Choisir la réponse au risque et les contrôles internes

- (a) Un risque externe ne se prête pas au même compromis rendement-coût *actif* qu'un risque interne car son origine échappe, par définition, au périmètre de décision de l'organisation : celle-ci ne peut ni modifier les processus, les personnes ou les systèmes qui le génèrent (il n'y en a pas, en son sein, à corriger), ni en réduire la probabilité par des contrôles internes. Le seul levier qui lui reste est donc de « diminuer l'exposition » (réduire son degré d'interaction avec la source du risque, par exemple limiter son activité dans une zone géographique instable) ou d'« optimiser la réponse d'atténuation » une fois le risque matérialisé (plans de continuité, assurance) — deux leviers qui agissent sur la *conséquence* de l'exposition au risque, non sur sa cause elle-même, à la différence des contrôles internes qui, eux, agissent directement sur la cause. Exemple de risque externe : une catastrophe naturelle affectant un centre de données régional, dont l'organisation ne peut empêcher la survenue mais dont elle peut réduire l'exposition (redondance géographique) ou l'impact (plan de continuité). Exemple de risque interne : une erreur de saisie manuelle dans le traitement des paiements, dont l'organisation peut directement réduire la probabilité par un contrôle préventif (validation à quatre yeux) puisque la cause — le processus de saisie — lui appartient entièrement.
- (b) Tolérer vise les « risques inhérents faibles ou déjà bien maîtrisés » : le niveau de risque inhérent y est bas, ou l'écart entre risque inhérent et risque résiduel (au sens du chapitre 3) y est déjà satisfaisant sans intervention supplémentaire. Terminer, à l'inverse, s'applique quel que soit le niveau de risque inhérent, dès lors que « les inconvénients dépassent clairement les bénéfices » de l'activité elle-même — c'est une décision qui porte sur l'opportunité de l'activité entière, non sur le niveau de risque qu'elle génère. Le cours qualifie Terminer d'« extrême » et non Tolérer car Terminer est *irréversible* et coûteux au sens large (perte de l'activité, de ses revenus et de sa clientèle), alors que Tolérer ne fait que *s'abstenir* d'ajouter une mesure d'atténuation à une activité par ailleurs poursuivie : les deux réponses n'impliquent certes aucune mesure d'atténuation active, mais l'une maintient le statu quo d'une situation déjà jugée acceptable, tandis que l'autre supprime une source de rendement pour éliminer un risque jugé inacceptable — un arbitrage nettement plus coûteux et donc réservé aux cas extrêmes.
- (c) Le rapprochement quotidien (au lieu de mensuel) est un contrôle **détectif** : il « signale la survenue d'un incident » plus tôt, exactement comme les « rapprochements de comptes » cités en exemple par le cours, sans empêcher l'erreur de se produire ni en réduire l'impact une fois découverte. La séparation des tâches est un contrôle **préventif** : elle « réduit la probabilité d'un incident en agissant sur ses causes », en l'occurrence en imposant que l'initiation, la validation et le règlement du virement soient assurés par des personnes distinctes, empêchant qu'une seule erreur individuelle suffise à exécuter un virement erroné. Le plafond de réversibilité des virements est un contrôle **correctif** : il ne change rien à la probabilité de l'erreur ni à sa détection, mais « réduit l'impact une fois l'incident survenu », exactement comme les « sauvegardes de données » citées en exemple, en limitant le montant effectivement perdu si le virement doit être annulé après coup. La formation renforcée des opérateurs est un contrôle **directif** : elle « structure la conduite des opérations en amont de tout événement », au même titre que les « politiques, procédures, formations » citées par le cours, en réduisant la probabilité d'erreur par la montée en compétence plutôt que par un mécanisme de contrôle intégré au processus lui-même.
- (d) Les cinq défaillances se classent ainsi : la **réutilisation de code obsolète** et le **contrôle de versions inadéquat** relèvent d'une défaillance **directive** — l'absence de politiques et de procédures de gestion du changement informatique suffisamment rigoureuses en amont du déploiement ; les **tests insuffisants** relèvent d'une défaillance **préventive** — un test adéquat aurait dû détecter le défaut de code *avant* sa mise en production, agissant ainsi sur la cause même de l'incident ; l'**absence de hiérarchisation des alertes** relève d'une défaillance **détective** — le système générerait bien des alertes, mais celles-ci n'ont pas permis de signaler l'incident avec l'urgence requise ; et l'**absence de procédure d'urgence pour activer le coupe-circuit** relève à la fois d'une défaillance

directive (aucune procédure documentée n'existait) et **correctrice** (le mécanisme censé limiter l'impact une fois l'incident déclenché n'a pas pu être actionné). Le coupe-circuit était conçu pour traiter un risque de probabilité *élevée* et d'impact *faible* au sens large — le type d'anomalie de routage relativement fréquente dans un système de trading automatisé à haute fréquence, pour laquelle un arrêt rapide limite mécaniquement la casse. Mais l'absence de procédure pour l'activer a transformé cette même défaillance ordinaire en un événement de probabilité faible (un tel enchaînement complet de défaillances est rare) mais d'impact potentiellement systémique : 460 millions USD perdus en 45 minutes, menaçant la survie même de l'entreprise — exactement la bascule que le cours attribue à l'automatisation défaillante d'un contrôle.

Corrigé de l'exercice 2 — Tester les contrôles, l'erreur humaine et l'amélioration continue

- (a) L'examen documentaire apporte, par rapport à l'auto-certification, une *preuve écrite indépendante* du contrôleur : il ne repose plus sur la seule déclaration de la personne responsable du contrôle, mais sur des traces vérifiables (documents, journaux) que l'examineur peut consulter lui-même, réduisant le risque qu'une défaillance non déclarée passe inaperçue. L'observation en temps réel apporte, par rapport à l'examen documentaire, la garantie que le contrôle est effectivement *exécuté tel que documenté* au moment où il l'est : un document peut décrire une procédure correcte sans que celle-ci soit suivie dans la pratique quotidienne, ce que seule l'observation directe peut vérifier. La reperformance apporte enfin, par rapport à la seule observation, une preuve *active et reproductible* de l'efficacité du contrôle plutôt qu'une simple confirmation de sa mise en œuvre formelle : en soumettant volontairement le contrôle à un cas test (transaction fictive, client mystère) dont le résultat attendu est connu à l'avance, elle vérifie que le contrôle produit effectivement le résultat recherché, et non pas seulement qu'il est exécuté de façon apparemment conforme — une observation en temps réel pouvant très bien constater qu'un contrôle « a lieu » sans pour autant qu'il soit efficace face à un cas réellement problématique.
- (b) Un contrôle à quatre yeux mal implémenté peut aboutir à ce que personne ne se sente responsable de sa bonne exécution car chacun des deux valideurs peut légitimement présumer que l'autre a déjà vérifié l'opération avec l'attention requise, un phénomène de diffusion de la responsabilité bien documenté en psychologie des organisations : la présence d'un second regard, loin de doubler la vigilance individuelle, tend à la diminuer chez chacun des deux acteurs, chacun se reposant implicitement sur l'autre. Ajouter un troisième ou un quatrième regard au même contrôle déjà mal implémenté aggraverait ce problème plutôt que de le résoudre, car chaque validateur supplémentaire dilue davantage encore la part de responsabilité perçue par chacun des viseurs individuels : avec quatre regards au lieu de deux, la probabilité subjective, pour chaque validateur, que « quelqu'un d'autre aura de toute façon vérifié » augmente, renforçant le relâchement collectif de vigilance — exactement ce que le cours désigne par « répondre à une défaillance de contrôle en ajoutant simplement « plus de la même chose » dilue encore davantage la responsabilité au lieu de la renforcer ».
- (c) L'opérateur de back-office, épuisé, qui inverse un chiffre illustre un **glissement** (« slip ») : une erreur involontaire due à la fatigue, sans aucune intention de nuire ni choix délibéré. Le conseiller commercial qui vend un produit inadapté sous l'effet d'incitations agressives illustre une **erreur fondée sur des règles ou des connaissances** (« mistake ») : un choix volontaire (la vente a bien été décidée consciemment) mais inadéquat au regard de l'intérêt du client. Le trader qui dépasse délibérément une limite qu'il connaît parfaitement illustre une **violation** : il connaît la règle et choisit sciemment de s'en écarter. Les réponses appropriées sont, respectivement : pour l'opérateur, « un meilleur environnement de travail et une charge de travail adaptée » (réduire la fatigue et la pression temporelle en fin de mois) ; pour le conseiller, des « contrôles directifs — formation, procédures documentées, fichiers d'aide », mais aussi, plus fondamentalement, une révision de la structure d'incitation commerciale elle-même qui motive ce choix inadéquat ; pour le trader, des « contrôles de supervision (hiérarchiques ou automatisés) et [...] le renforcement d'une culture de conformité qui récompense le respect des règles ». Appliquer au trader la réponse de l'opérateur (améliorer son environnement de travail) serait contre-productif car son

acte n'a rien d'involontaire ni de lié à la fatigue : il a délibérément choisi de transgresser une règle qu'il maîtrise, un problème de *volonté* et de *contrôle* que le confort de son poste de travail ne modifie en rien. Inversement, soumettre l'opérateur fatigué à une supervision renforcée et à une culture de sanction disproportionnée traiterait comme une faute intentionnelle ce qui n'est qu'une défaillance humaine ordinaire liée aux conditions de travail, ce qui découragerait la remontée spontanée de ce type d'erreur sans pour autant en réduire la fréquence, puisque la cause réelle (la fatigue) resterait intacte.

- (d) Le DMAIC se déroule en cinq étapes : **définir** le problème et les objectifs d'amélioration, **mesurer** la performance actuelle du processus, **analyser** les causes de la variabilité ou du gaspillage observés, **améliorer** le processus en mettant en œuvre des solutions, et **contrôler** pour s'assurer que l'amélioration se maintient dans la durée. Le PDSA se déroule en quatre étapes : **planifier** le changement à tester, **l'exécuter** à petite échelle, **étudier** les résultats obtenus, et **agir** en généralisant le changement s'il est concluant ou en l'ajustant sinon. Les deux cycles poursuivent un objectif méthodologique commun malgré leurs étapes nommées différemment : tous deux visent à modifier durablement la *conception même du processus* (sa variabilité, son gaspillage, sa qualité) plutôt qu'à réagir après la survenue d'un incident isolé — une logique de réduction du risque *à la source*, en amont de toute matérialisation, alors que les contrôles détectifs et correctifs de l'exercice 1 interviennent, par construction, pendant ou après l'incident. Cette logique complète les quatre types de contrôles sans s'y substituer : un processus mieux conçu (grâce au DMAIC ou au PDSA) réduit le besoin même de s'appuyer sur des contrôles détectifs et correctifs pour rattraper ses défaillances, mais ne dispense jamais d'un contrôle préventif ou directif résiduel, aucun processus, même optimisé, n'étant à l'abri de toute variabilité future.

Corrigé de l'exercice 3 — Projets, continuité, transfert du risque et réputation

- (a) Le cinquième volet — « risques et leur atténuation » — est structurellement plus difficile à documenter pour une acquisition que pour un nouveau produit interne car, dans le second cas, l'organisation *conçoit elle-même* le produit, ses processus, les personnes qui l'opéreront et les systèmes qui le supporteront : elle peut donc cartographier les risques et leurs contrôles *avant même* le lancement, dans le cadre du dossier d'affaires. Dans le cas d'une acquisition, à l'inverse, l'entité acquise arrive avec des processus, des personnes et des systèmes déjà en place, construits par une autre organisation selon d'autres pratiques, souvent « mal documentés au moment de la diligence raisonnable » : l'acquéreur ne peut évaluer ce qu'il ne peut observer directement, et le risque opérationnel, contrairement au risque de crédit d'un portefeuille (dont chaque prêt individuel porte une trace contractuelle et un historique de paiement aisément consultables), ne laisse par nature aucune trace comparable pour la qualité des contrôles internes, la culture du risque ou les compétences du personnel repris. La nature même du risque opérationnel — résultant de « processus, de personnes et de systèmes construits progressivement » au fil du temps, souvent de façon informelle — explique ainsi pourquoi une diligence raisonnable, aussi rigoureuse soit-elle, ne peut en révéler qu'une fraction : un « squelette dans le placard » peut rester invisible tant qu'aucun événement ne vient précisément révéler la défaillance sous-jacente, parfois « des mois, voire des années après la transaction ».
- (b) Le RPO se fixe en amont du sinistre car il dépend uniquement d'une décision de politique de sauvegarde prise *avant* tout incident — la fréquence à laquelle l'organisation sauvegarde ses données détermine mécaniquement le volume de données qu'elle risque de perdre si un incident survient juste avant la prochaine sauvegarde prévue ; le RPO est donc un paramètre de conception du système, non une mesure de la réponse à un événement. Le RTO, à l'inverse, ne peut être respecté *qu'après* le sinistre, car son respect dépend de l'efficacité effective de la réponse d'urgence et du rétablissement une fois l'incident survenu : fixer un RTO cible est une décision ex ante, mais le vérifier ou l'atteindre est nécessairement un exercice ex post, qui dépend de facteurs (rapidité, compétence des intervenants mobilisés) que seule la survenue réelle d'un incident permet de tester pleinement, même si des simulations « war room » permettent de s'en approcher à l'avance. Parmi les trois qualités de gestion de crise : la **rapidité** est la plus directement mobilisée lors de la phase de **crise** elle-même (« les premières minutes ou heures

»), où chaque minute perdue avant de cerner la nature du problème aggrave potentiellement son ampleur ; la **compétence** des intervenants est le plus directement mobilisée lors de la **réponse d'urgence** (« évaluation et décision sur la marche à suivre »), où le bon diagnostic et la bonne décision dépendent directement de l'expertise mobilisée, y compris externe ; et la **transparence** est le plus directement mobilisée lors du **rétablissement** et surtout de la **restauration**, les phases les plus longues et les plus visibles pour les parties prenantes externes, où la dissimulation ou la minimisation, selon le cours, « alimente[nt] toujours des développements plus négatifs que la vérité assumée ».

- (c) Les petites pertes récurrentes sont justement les moins bien adaptées à un transfert par assurance, malgré leur prévisibilité apparente, car cette prévisibilité même les rend économiquement peu intéressantes à assurer : un assureur, confronté à un risque dont la fréquence et la sévérité sont bien connues à l'avance, tarifiera sa prime de façon à couvrir très exactement l'espérance de perte, plus ses frais de gestion et sa marge — de sorte que la prime finit structurellement par excéder la perte attendue elle-même, sans réduction significative de l'incertitude puisque celle-ci était déjà faible pour ce type de pertes régulières et prévisibles ; l'auto-assurance, qui ne fait que provisionner ce même montant attendu sans chargement, devient alors mécaniquement moins coûteuse. Les événements extrêmes, à l'inverse, présentent une incertitude bien plus grande sur leur sévérité, ce qui justifie de payer une prime pour transférer précisément cette incertitude à un tiers mieux capitalisé pour l'absorber. La clause « jamais la responsabilité vis-à-vis du client final » protège, dans les deux cas, le principe selon lequel un transfert de risque opérationnel est un arrangement *financier ou opérationnel interne* entre l'organisation et un tiers (assureur ou prestataire), qui ne modifie en rien la relation contractuelle et la responsabilité juridique de l'organisation envers son propre client final : celui-ci n'est partie ni au contrat d'assurance ni au contrat d'externalisation, et continue donc de se retourner légitimement contre l'organisation elle-même en cas de préjudice, quelle que soit la cause opérationnelle sous-jacente ou le tiers finalement responsable en interne.
- (d) Le signalement rapide aux autorités et la communication transparente du détail des données compromises illustrent la **raison** — une explication transparente des causes et de l'ampleur de l'incident. Les excuses publiques du PDG assumant l'entière responsabilité illustrent le **regret** — une reconnaissance sincère de la faute de l'établissement. L'indemnisation ciblée (surveillance du vol d'identité) et l'indemnisation générale (renforcement des contrôles) illustrent toutes deux le **remède** — une solution satisfaisante d'indemnisation des parties prenantes affectées, la première réparant le préjudice individuel immédiat, la seconde prévenant sa répétition pour l'ensemble de la base de clients. La phrase « la relation fonctionne dans les deux sens » explique la préservation du capital réputationnel de Capital One car elle signifie que la réputation n'est pas seulement un *résultat* passif de la qualité des contrôles, mais aussi un actif que la *qualité de la réponse à la crise elle-même* peut reconstituer après coup : en respectant scrupuleusement les trois R malgré une défaillance de contrôle initiale sévère, Capital One a démontré aux parties prenantes une capacité de gestion de crise qui a partiellement compensé, aux yeux du marché et des clients, la faute initiale — la résilience réputationnelle se manifestant ici non par l'absence d'incident, mais par la qualité de la réponse apportée une fois l'incident survenu.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — L'atténuation des risques à la lumière des chapitres 3, 2, 1 et de l'introduction

- (a) Le chapitre 3 emploie effectivement, avant que ce chapitre ne les définisse formellement, deux notions qui appartiennent à la matière de ce chapitre : la « BCM classique [...] articulée [...] autour [...] du délai de reprise (RTO) », que ce chapitre définit précisément comme « la durée maximale d'interruption tolérable pour un processus ou un service » au sein d'un processus BCM lui-même défini ici comme « un processus continu qui identifie les activités critiques [...] et prépare les moyens de [...] rétablir rapidement le service » ; et « l'effet des contrôles en place » sur l'écart entre risque inhérent et risque résiduel, alors que ce chapitre est précisément celui qui

catalogue ces contrôles (préventifs, détectifs, correctifs, directifs) que le chapitre 3 ne faisait que présupposer comme une catégorie déjà connue du lecteur. L'ordre de lecture du cours (mesure au chapitre 3, atténuation au chapitre 4) ne coïncide donc pas avec l'ordre de dépendance conceptuelle complète : le lecteur du chapitre 3 devait déjà posséder une notion au moins intuitive de ce qu'est un contrôle et de ce qu'est un délai de reprise pour suivre pleinement son propos, alors même que ces notions ne sont formellement développées qu'au chapitre suivant. Cela illustre que le cycle en quatre étapes du cours est *itératif* plutôt que strictement linéaire : la surveillance (quatrième étape) réinjecte ses enseignements dans l'identification (première étape) selon l'introduction elle-même, et de la même façon, l'évaluation (chapitre 3) et l'atténuation (chapitre 4) s'appuient mutuellement l'une sur l'autre — mesurer un risque résiduel exige de savoir ce qu'est un contrôle, et concevoir un contrôle exige de savoir ce que mesure le risque résiduel qu'il vise à réduire —, chaque étape du cycle n'étant pleinement intelligible qu'à la lumière des autres, plutôt qu'une séquence où chaque notion n'apparaîtrait qu'une seule fois avant de ne plus jamais être requise.

- (b) Les deux définitions coïncident presque mot pour mot : le chapitre 2 définit les préventifs comme réduisant « la probabilité en agissant sur les causes », ce chapitre comme réduisant « la probabilité d'un incident en agissant sur ses causes » ; le chapitre 2 définit les détectifs comme identifiant « l'événement pendant ou après sa survenue », ce chapitre comme signalant « la survenue d'un incident et accélér[ant] sa résolution » ; le chapitre 2 définit les correctifs comme réduisant « l'impact d'un incident déjà survenu », ce chapitre comme réduisant « l'impact une fois l'incident survenu » ; et le chapitre 2 définit les directifs comme des « procédures, formations et lignes directrices qui structurent la conduite des opérations », ce chapitre comme des « politiques, procédures, formations » qui « structurent la conduite des opérations en amont de tout événement ». Ce que ce chapitre ajoute, conformément à sa propre annonce (« le chapitre 4 détaille ces contrôles »), est l'appareil pratique que le chapitre 2 ne faisait qu'annoncer : des exemples concrets pour chaque type (séparation des tâches, rapprochements de comptes, sauvegardes, politiques), la hiérarchie entre contrôle clé et contrôle secondaire, les quatre niveaux de test de rigueur croissante, et le risque spécifique de l'automatisation illustré par le cas Knight Capital — le chapitre 2 nommait et classait les contrôles au sein de sa taxonomie des causes, ce chapitre les rend opérationnels. La typologie de James Reason (glissement, erreur, violation) est bien un raffinement interne à la seule catégorie « personnes » du sigle PPSE, car elle distingue des actions humaines par leur *intention* (involontaire, volontaire mais inadéquate, délibérément transgressive) — une distinction qui n'a de sens que pour un acteur doté d'une volonté et d'une conscience des règles. Les trois autres catégories PPSE (processus, systèmes, événements externes) ne se prêtent pas à ce type de décomposition par intention car un processus mal conçu, un système défaillant ou un événement externe n'ont, par définition, aucune intention propre : leur défaillance se décrit en termes de conception, de fiabilité technique ou de probabilité d'occurrence, jamais en termes de choix délibéré ou d'inattention, des notions réservées à l'acteur humain.
- (c) Les quatre niveaux de test se répartissent naturellement selon le modèle des trois lignes de défense : l'**auto-certification** relève typiquement de l'auto-évaluation par la **première ligne** elle-même — les « propriétaires du risque » responsables de « la maîtrise quotidienne des risques inhérents à [leur] activité » déclarent eux-mêmes le bon fonctionnement de leurs contrôles — tandis que l'**observation en temps réel** et surtout la **reperformance** exigent l'indépendance propre à la **deuxième ligne** (qui « exerce [...] une supervision et un rôle de challenge » via sa méthodologie de test) ou à la **troisième ligne**, l'audit interne, qui « fournit une assurance indépendante sur l'ensemble du dispositif », y compris sur la robustesse des tests eux-mêmes menés par la deuxième ligne. Le cas Kerviel relève d'une **violation** au sens strict du chapitre 4 : un trader qui connaît parfaitement les limites de position qui lui sont imposées et choisit délibérément de les dépasser, en dissimulant ses positions pendant des mois — un manquement intentionnel, non une accumulation fortuite de défaillances. Le cas Knight Capital, à l'inverse, relève d'une accumulation de défaillances de contrôles préventifs (tests insuffisants), détectifs (absence de hiérarchisation des alertes) et directifs (contrôle de versions inadéquat, absence de procédure d'urgence), sans qu'aucun individu identifié n'ait sciemment cherché à enfreindre

une règle connue : c'est un échec systémique de conception et de gestion du changement, non une transgression délibérée. Cette différence de nature explique pourquoi le chapitre 1 rapporte, pour le cas Kerviel, une réponse de *culture et de supervision* (partage des leçons apprises entre entités pour renforcer la vigilance collective et la remontée précoce des signaux d'alerte face à une possible violation future), alors que ce chapitre appelle, pour Knight Capital, une réponse *technique* de gestion du changement informatique et de contrôle de version : on ne traite pas une défaillance de volonté individuelle et une défaillance de processus technique par le même type de remède, exactement comme l'exercice 2(c) l'établit pour les glissements, erreurs et violations prises individuellement.

- (d) L'automatisation d'un contrôle, qui « transforme un risque de probabilité élevée et d'impact faible en un risque de probabilité faible mais d'impact potentiellement systémique », est un mécanisme concret de déplacement le long de la queue épaisse de l'introduction (« une multitude de petites pertes coexistent avec un petit nombre de pertes extrêmes ») : avant automatisation, le risque se manifestait par de nombreuses petites défaillances humaines dispersées vers le corps de la distribution des pertes ; après automatisation, il se concentre en un nombre très réduit d'événements potentiellement extrêmes, exactement le type de queue épaisse que l'introduction attribue au risque opérationnel dans son ensemble — sauf qu'ici, ce n'est plus une propriété statistique subie de l'extérieur, mais une conséquence directe d'une décision de gestion interne. C'est en cela que le risque devient « dynamique » au sens précis de l'introduction (« sa nature évolue avec celle de l'activité et de l'environnement de l'organisation ») par un canal que l'introduction elle-même n'explicite pas : ce n'est pas seulement l'environnement externe qui fait évoluer la nature du risque opérationnel dans le temps, c'est la propre trajectoire technologique de l'organisation (automatiser tel ou tel contrôle) qui redessine, à chaque décision, la courbe fréquence-sévérité de ses propres risques. La séparation des tâches, appliquée « entre l'initiation, la validation et le règlement d'une transaction », est la traduction la plus directe du principe de décentralisation de l'introduction (« tout le monde est un gestionnaire du risque » car le risque « ne peut pas être centralisé ») : ce contrôle exige structurellement l'intervention d'au moins deux ou trois personnes occupant des fonctions distinctes de la chaîne opérationnelle elle-même, et ne pourrait, par construction, jamais être exécuté par une seule fonction centrale de gestion du risque opérationnel, qui n'initie, ne valide ni ne règle elle-même aucune transaction : la maîtrise du risque reste nécessairement au plus près de l'activité qui le génère, exactement comme l'introduction l'annonce.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — Assurance externe et auto-assurance d'un risque opérationnel, chiffrés

On a $\lambda = 4$ événements par an et trois bandes de sévérité (v_i, p_i) : (200, 60 %), (2 000, 32 %), (15 000, 8 %), en milliers d'euros. La franchise est $D = 300$ k€ et le plafond de garantie $L = 8 000$ k€ (l'assureur couvre la tranche $]D, D + L] =]300, 8 300]$ k€ par événement), pour une prime $P = 6 200$ k€.

- (a) La sévérité moyenne par événement est $200 \times 0,60 + 2\,000 \times 0,32 + 15\,000 \times 0,08 = 120,00 + 640,00 + 1\,200,00 = 1\,960,00$ k€. La perte annuelle attendue sans assurance est $EL = \lambda \times 1\,960,00 = 4 \times 1\,960,00 = 7\,840,00$ k€.
- (b) Bande 1 (200 k€, sous la franchise de 300 k€) : entièrement retenue, retenu = 200 k€, cédé = 0 k€. Bande 2 (2 000 k€) : l'excédent sur la franchise, $2\,000 - 300 = 1\,700$ k€, reste sous le plafond de 8 000 k€ et est donc intégralement cédé ; retenu = 300 k€ (la franchise), cédé = 1 700 k€. Bande 3 (15 000 k€) : l'excédent sur la franchise est $15\,000 - 300 = 14\,700$ k€, plafonné à $L = 8\,000$ k€ pour l'assureur ; retenu = $300 + (14\,700 - 8\,000) = 300 + 6\,700 = 7\,000$ k€, cédé = 8 000 k€ (le plafond). Le montant retenu moyen par événement est $200 \times 0,60 + 300 \times 0,32 + 7\,000 \times 0,08 = 120,00 + 96,00 + 560,00 = 776,00$ k€, et le montant cédé moyen est $0 \times 0,60 + 1\,700 \times 0,32 + 8\,000 \times 0,08 = 0,00 + 544,00 + 640,00 = 1\,184,00$ k€ (la somme des deux, 1 960,00 k€, retrouve bien la sévérité moyenne du (a)). La perte annuelle attendue retenue par la banque est $4 \times 776,00 = 3\,104,00$ k€, et la perte annuelle attendue cédée à l'assureur (les sinistres annuels attendus) est $4 \times 1\,184,00 = 4\,736,00$ k€.

- (c) Le chargement implicite de l'assureur est $P/\text{sinistres attendus} - 1 = 6\,200,00/4\,736,00 - 1 = 30,91\%$: la prime demandée excède de près d'un tiers l'espérance des sinistres qu'elle couvre. Le coût total annuel attendu avec assurance (prime plus perte retenue attendue) est $6\,200,00 + 3\,104,00 = 9\,304,00$ k€, à comparer au coût total annuel attendu sans assurance de **7 840,00** k€ calculé au (a) : l'assurance coûte, en espérance, $9\,304,00 - 7\,840,00 = 1\,464,00$ k€ de plus par an que l'auto-assurance totale. Ce surcoût attendu est parfaitement compatible avec l'affirmation du cours : l'assurance « réduit la volatilité du résultat en échange d'une prime régulière », elle ne prétend jamais réduire le coût *attendu* du risque — au contraire, elle l'augmente structurellement du montant du chargement de l'assureur, en échange d'une protection contre les scénarios extrêmes que seule une entité mieux capitalisée peut absorber sans mettre en péril sa solvabilité.
- (d) Si l'événement de 15 000 k€ (bande 3) se matérialise, la banque assurée décaisse la prime déjà payée plus le montant retenu de cet événement, soit $6\,200,00 + 7\,000,00 = 13\,200,00$ k€, contre **15 000,00** k€ pour la banque non assurée qui supporte la perte en totalité — un écart de $15\,000,00 - 13\,200,00 = 1\,800,00$ k€ en faveur de l'assurance sur cet événement précis. Combiné au résultat du (b) sur la bande 1, entièrement absorbée par la franchise et donc jamais transférée à l'assureur quel que soit le nombre d'occurrences, ce résultat illustre exactement la prescription du cours : l'assurance profite pleinement à l'événement extrême de la bande 3 (elle transfère 8 000,00 k€ sur les 15 000,00 k€ de perte, allégeant nettement le choc pour la banque), alors qu'elle ne joue structurellement aucun rôle pour les petites pertes récurrentes de la bande 1, entièrement sous la franchise et donc laissées, de fait, à l'auto-assurance — conformément à l'idée que l'assurance a du sens « typiquement [pour] les événements extrêmes [...] plutôt que les petites pertes récurrentes que beaucoup de grands établissements préfèrent auto-assurer ».

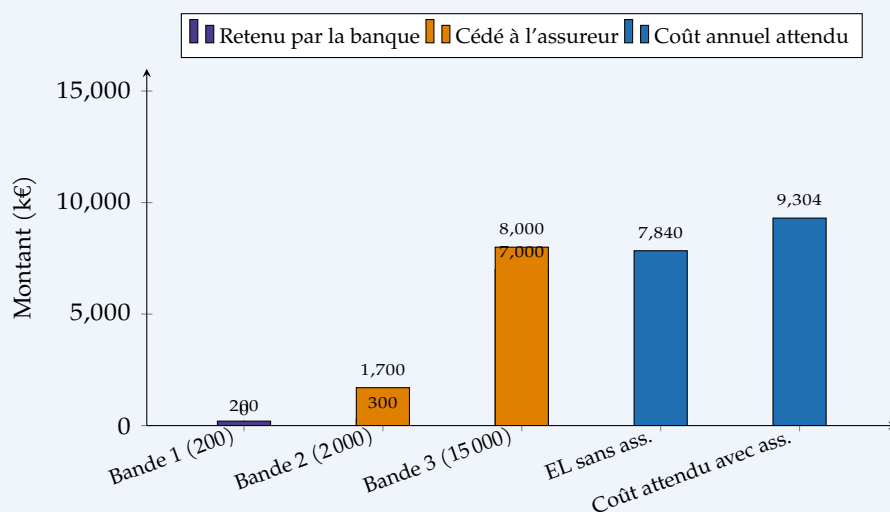


FIG. 1 : Répartition retenu/cédé par bande de sévérité (bleu/orange) et coût annuel attendu total sans et avec assurance (vert) — exercice 5.

Corrigé de l'exercice 6 — Contrôles automatisés et coût d'un incident majeur, chiffrés

Le rythme de perte est $r = 650$ k€ par minute. Sans contrôle automatisé, la durée totale est $t_0 = 38 + 4 = 42$ minutes. Avec détection automatisée seule, $t_1 = 3 + 4 = 7$ minutes. Avec détection automatisée et coupe-circuit automatique, $t_2 = 3 + 1 = 4$ minutes.

- (a) La perte totale sans contrôle automatisé est $L_0 = r \times t_0 = 650 \times 42 = 27\,300,00$ k€.
- (b) Avec détection automatisée seule, la perte totale est $L_1 = 650 \times 7 = 4\,550,00$ k€. Avec détection automatisée et coupe-circuit automatique, la perte totale est $L_2 = 650 \times 4 = 2\,600,00$ k€. La perte évitée par la détection automatisée seule, par rapport à l'absence de tout contrôle, est $L_0 - L_1 = 27\,300,00 - 4\,550,00 = 22\,750,00$ k€. La perte supplémentaire évitée par l'ajout du coupe-circuit automatique, par rapport à la détection automatisée seule, est $L_1 - L_2 = 4\,550,00 - 2\,600,00 = 1\,950,00$ k€.

1 950,00 k€.

- (c) Avec $p = 5\%$, la perte annuelle attendue est $E_0 = p \times L_0 = 0,05 \times 27\,300,00 = 1\,365,00$ k€ sans contrôle, $E_1 = 0,05 \times 4\,550,00 = 227,50$ k€ avec détection seule, et $E_2 = 0,05 \times 2\,600,00 = 130,00$ k€ avec détection et coupe-circuit. La réduction de perte annuelle attendue permise par la détection automatisée seule est $E_0 - E_1 = 1\,365,00 - 227,50 = 1\,137,50$ k€, et la réduction supplémentaire permise par l'ajout du coupe-circuit est $E_1 - E_2 = 227,50 - 130,00 = 97,50$ k€. Le bénéfice net de la détection automatisée seule (coût 850,00 k€/an) est $1\,137,50 - 850,00 = +287,50$ k€ : cet investissement est **justifié** sur le seul critère de la perte attendue. Le bénéfice net du coupe-circuit automatique en supplément (coût 620,00 k€/an) est $97,50 - 620,00 = -522,50$ k€ : cet investissement, pris isolément, n'est **pas justifié** sur le seul critère de la perte attendue.
- (d) Sur le seul critère du (c), la société ne devrait pas nécessairement renoncer au coupe-circuit automatique : le cours avertit précisément que l'automatisation d'un contrôle « transforme un risque de probabilité élevée et d'impact faible en un risque de probabilité faible mais d'impact potentiellement systémique », et le cas Knight Capital illustre qu'une telle transformation, une fois mal maîtrisée (ici par l'« absence de procédure d'urgence pour activer le coupe-circuit »), peut produire une perte dépassant très largement l'espérance mathématique calculée sur la base d'une fréquence moyenne. L'argument que fournit le cours, au-delà du calcul de perte attendue, est que ce type d'événement relève précisément de la queue épaisse et du caractère potentiellement « systémique » du risque opérationnel : un bénéfice net négatif en espérance ne mesure que la moyenne sur un grand nombre d'occurrences hypothétiques, alors que le risque réel porté par l'entreprise est celui d'un unique événement extrême pouvant menacer sa solvabilité ou sa survie même — un risque de queue que l'espérance mathématique, en le lissant sur l'ensemble des scénarios possibles, tend structurellement à sous-pondérer par rapport à ce que la gouvernance et l'appétit pour le risque de l'établissement pourraient par ailleurs juger inacceptable de laisser sans second filet de protection.

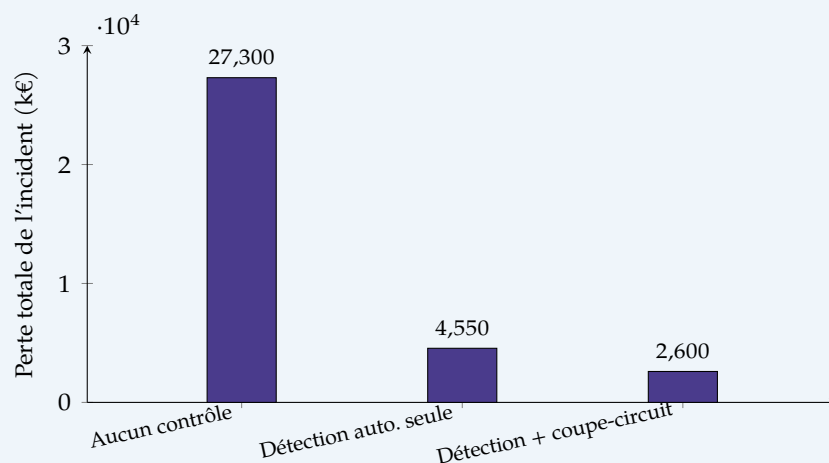


FIG. 2 : Perte totale de l'incident selon le niveau de contrôle automatisé en place (rythme de perte constant de 650 k€/minute) — exercice 6.